

BÁO CÁO KIỂM THU TECHNICAL AUDIT & ACTION PLAN

Đánh giá tính sẵn sàng Production & Lộ trình khắc phục hệ thống LaDux Backend

DỰ ÁN: LaDux E-Commerce Service (Java / Spring Boot)

NGÀY BÁO CÁO: 26/07/2026

TÁC GIẢ: Tui (AI Tech Lead Audit)

NGƯỜI NHẬN: Khang (Lead Engineer)

TRẠNG THÁI: **NOT PRODUCTION READY (Cần khắc phục khẩn cấp)** XÁC MINH: Local Maven Compile Verified

3 P0

LỖI CẤP BÁCH (BUILD/
SCHEMA/SEC)

3 P1

RỦI RO RỦI RO CAO
(LOCK/CONFIG/AUTH)

8 Module

CẦN BỔ SUNG / THIẾU
DTO

Vững Chắc

KIẾN TRÚC CORE &
TRANSACTION

1. Tổng Quan Hiện Trạng & Đánh Giá Chung

Hệ thống Backend LaDux hiện **chưa sẵn sàng để triển khai Production**. Lý do lớn nhất là lệnh build cơ bản `mvn -q -DskipTests compile` đang bị **FAIL** ngay từ giai đoạn biên dịch. Nguyên nhân gốc rễ xuất phát từ việc thực hiện **refactor domain model từ Product sang ProductVariant mới đi được một nửa**, dẫn đến sự bất tương thích dữ liệu toàn cục giữa Controller, Service, DTO và Repository.

Bên cạnh đó, dù sửa thành công lỗi biên dịch code, ứng dụng vẫn sẽ thất bại ở thời điểm khởi động (startup) do cấu hình Flyway migration (`ddl-auto=validate`) không khớp với khai báo Hibernate Entity.

✓ Điểm Sáng Nền Tảng Kiến Trúc (Architecture Strengths)

Dù đang gặp trục trặc refactor, nền tảng hệ thống của Khang có định hướng kiến trúc rất chuẩn mực:

- Modular Monolith:** Phân chia tầng Controller → Service → Repository mạch lạc, dễ debug, phù hợp quy mô hiện tại.
- Tối ưu DB & Transaction:** Đã bật `open-in-view=false`, dùng `BigDecimal` cho tính toán tiền tệ, ứng dụng Optimistic Locking/Atomic Update bảo vệ tồn kho.
- Tích hợp hạ tầng:** Có Flyway Versioning, Redis Cache & Rate Limiting, Spring Actuator, Docker Container Non-root.
- Xử lý nghiệp vụ phức tạp:** Đã triển khai Order State Machine và VNPay Webhook đạt chuẩn với HMAC signature verification & Idempotency.

2. Chi Tiết Các Phát Hiện Vấn Đề (Findings Audit)

P0 - CRITICAL 1. Backend Thất Bại Ngay Khi Biên Dịch (Compile Failures)

Do refactor dở dang từ Product sang ProductVariant, các module bị gây liên kết phụ thuộc:

- `ProductVariantServiceImpl.java:14`: Không implement đúng interface `ProductVariantService`.
- `LineDraft.java` đã đổi thuộc tính sang `productVariant`, nhưng `OrderServiceImpl.java:174` vẫn tiếp tục gọi method cũ `draft.product()`.
- `CartResponse.java:21` và `PricingServiceImpl.java:14` cố gắng đọc `Product.basePrice` / `discountPrice` — hai trường này đã bị xóa khỏi Entity `Product` để chuyển sang Variant.

P0 - CRITICAL 2. Schema Flyway Lệnh Hoàn Toàn So Với Entity Mapping

Khi bật Hibernate validation (`ddl-auto=validate`), ứng dụng sẽ crash lập tức do schema DB chưa đồng bộ:

- `ProductVariant.java:30` yêu cầu các cột FK/Attribute: `color_id`, `ram`, `rom`. Tuy nhiên migration script `V28__sync_schema_with_current_entities.sql:16` lại tạo cột `color`, `storage` dạng chuỗi và **không hề tạo bảng `colors`**.
- `Order.java:77` khai báo `shippingAddress` dưới dạng Embeddable Object, nhưng schema gốc `v1__init_schema.sql:104` vẫn lưu dưới dạng cột đơn `shipping_address TEXT`.

P0 - CRITICAL 3. Lỗ Hổng Phân Quyền & Bật Mở Route Admin (Security Exposure)

Hệ thống bảo mật Spring Security đang có những sơ hở nghiêm trọng cho phép bypass quyền Admin:

- `SecurityConfig.java:102` chỉ khóa đường dẫn `/actuator/**`, tất cả endpoint còn lại chỉ yêu cầu trạng thái chung `authenticated` (người dùng CUSTOMER thông thường cũng có thể gọi API Admin nếu biết URL).
- `AdminColorController.java:18` bị sai URL chuẩn (`/admin/color` thay vì `/api/v1/admin/colors`) và thiếu hoàn toàn Annotation bảo mật `@PreAuthorize`.
- `AdminNotificationController.java:13` thiếu Annotation `@PreAuthorize` ở cấp class/method.

P0/P1 4. Cấu Hình Scheduler Lock Cập Nhật Thiếu

Đã bật cấu hình khóa phân tán `@EnableSchedulerLock` tại `ShedLockConfig.java:13`. Tuy nhiên, background job quan trọng `expirePendingOrders()` tại `OrderStateMachineImpl.java:77` chỉ khai báo `@Scheduled` mà **thiếu `@SchedulerLock`**.

Hậu quả: Khi triển khai scale từ 2 instance trở lên trên Production, job này sẽ bị kích hoạt trùng lặp đồng thời ở nhiều node, gây ra xung đột dữ liệu trạng thái đơn hàng.

P1 - HIGH 5. Rủi Ro Cấu Hình Môi Trường Production

- `docker-compose.yml:9` mặc định chạy profile `dev` và fallback JWT Secret key cứng tại line 13.
- `application-prod.properties:3` vẫn bật `show-sql=true` (làm lộ tham số truy vấn vào log và suy giảm hiệu năng IO).
- `application.properties:42` Redis trên Prod chưa override host, vẫn trở mặc định về `localhost`.
- `application-dev.properties:10` có flag `clean-on-validation-error=true` — Cực kỳ nguy hiểm nếu cấu hình dev bị lọt sang Prod vì Flyway sẽ drop toàn bộ bảng khi có lỗi validation.

P1 - HIGH 6. Bảo Mật Xác Thực Chưa Đạt Chuẩn (Auth Hardening)

- `RefreshToken.java:40` lưu trữ Refresh Token dưới dạng chuỗi thô (plain-text) trong CSDL và truy vấn trực tiếp bằng token thô (`RefreshTokenService.java:57`). Nếu DB bị rò rỉ, kẻ tấn công có thể chiếm đoạt session ngay lập tức.
- `AuthController.java:76` trả Access Token trực tiếp trong Response Body, vô hiệu hóa cơ chế bảo vệ của HttpOnly Cookie đối với luồng authentication này.

3. Danh Sách Các Module / CRUD Còn Thiếu Hoặc Chưa Hoàn Thiện

MODULE / CHỨC NĂNG	HIỆN TRẠNG ĐÃ PHÁT HIỆN	YÊU CẦU HOÀN THIỆN
Role & Permission	Đã có enum <code>RoleName</code> (<code>ADMIN</code> , <code>STAFF_SALES</code> , <code>STAFF_INVENTORY</code> , <code>CUSTOMER</code>)	Chưa có CRUD Role. Các role Nhân viên (<code>STAFF_*</code>) chưa được gán vào bất kỳ <code>@PreAuthorize</code> nào.
ProductVariant & Public DTO	CRUD Admin hỏng do compile fail. <code>ProductResponse</code> chưa chứa danh sách variants.	Sửa CRUD Admin, cập nhật <code>updateProduct()</code> hỗ trợ đồng bộ variants, thêm API lấy variant theo product.
Color Master Data	Thiếu API GET list/detail. Route sai chuẩn. Schema DB chưa có bảng <code>colors</code> .	Tạo migration bảng <code>colors</code> , viết lại Controller theo đường dẫn <code>/api/v1/admin/colors</code> có kiểm tra quyền.
Shipping & Fulfillment	Mới chỉ dừng lại ở thuộc tính đơn giản <code>trackingNumber</code> trong Order.	Bổ sung Entity Shipment, Nhà vận chuyển (Carrier) và lịch sử trạng thái giao hàng (Tracking events).
Return & Refund Flow	<code>OrderStatus</code> thiếu quy trình đổi trả. <code>PaymentStatus</code> chưa có trạng thái Hoàn tiền.	Bổ sung trạng thái <code>RETURNED</code> , <code>REFUNDED</code> vào State Machine & tích hợp API hoàn tiền VNPAY/Manual.
Customer Loyalty	<code>loyalty/totalSpent</code> đang phải sửa thủ công bởi Admin tại <code>CustomerServiceImpl:60</code> .	Tự động cộng điểm loyalty và tích lũy <code>totalSpent</code> thông qua Domain Event khi đơn chuyển <code>DELIVERED</code> .
Notification Broadcast	Đang query load toàn bộ User lên RAM và insert đồng bộ vào DB (<code>NotificationServiceImpl:81</code>).	

MODULE / CHỨC NĂNG	HIỆN TRẠNG ĐÃ PHÁT HIỆN	YÊU CẦU HOÀN THIỆN
		Chuyển sang cơ chế Batch processing / Outbox Pattern + Async Worker để tránh nghẽn server khi lượng User lớn.
Audit Logging	Mới có nhật ký giao dịch đơn hàng (<code>OrderHistory</code>) và biến động kho (<code>StockMovement</code>).	Bổ sung AOP Audit Log ghi nhận toàn bộ hành động chỉnh sửa/xóa dữ liệu của Admin trên hệ thống.

4. Lộ Trình Khắc Phục Tối Ưu (Áp dụng Nguyên Tắc 80/20)

Để đưa hệ thống lên trạng thái hoạt động ổn định trong thời gian ngắn nhất, Khang nên tập trung **20% công sức vào nhóm nhiệm vụ Cấp Bách (Giai Đoạn 1)** để giải quyết **80% rủi ro nghẽn mạch** của dự án.



giai đoạn 1: tập trung fix nền tảng (ưu tiên hàng đầu - P0)

- Bước 1 - Chốt Domain Model & Sửa Lỗi Biên Dịch:**

Xác định chuẩn: `Product` đóng vai trò Catalog Shell (thông tin chung, thương hiệu, danh mục). `ProductVariant` đóng vai trò quản lý đơn vị lưu kho SKU, Giá bán (`price` , `discountPrice`), Tồn kho (`stock`), Màu sắc (`color_id`), Cấu hình (`ram` , `rom`). Sau đó refactor toàn bộ `CartItem` , `OrderItem` , `PurchaseOrderItem` , `StockMovement` và Service định giá sang trở tới Variant ID.
- Bước 2 - Đồng Bộ Flyway Migration (Forward-Only):**

Tạo migration script mới (ví dụ `v29__fix_product_variant_and_order_schema.sql`) tạo bảng `colors` , thêm khóa ngoại `color_id` , sửa các cột `ram` , `rom` , đồng bộ cấu trúc `shipping_address` dạng Embeddable hoặc quy về JSON/String DTO nhất quán.
- Bước 3 - Siết Chặt Bảo Mật Admin & Chuẩn Hóa Endpoint:**

Cập nhật `SecurityConfig` thêm quy tắc bắt buộc `.requestMatchers("/api/v1/admin/**").hasRole("ADMIN")` (hoặc kèm quyền Staff). Đổi route `AdminColorController` về `/api/v1/admin/colors` và gắn đầy đủ `@PreAuthorize("hasRole('ADMIN')")` .
- Bước 4 - Khóa Phân Tán Job & Đặt CI Build Check:**

Thêm annotation `@SchedulerLock(name = "expirePendingOrdersLock")` cho job trong `OrderStateMachineImpl` . Thiết lập GitHub Actions Workflow cơ bản chạy `mvn -q -DskipTests compile` và `mvn test` ở mỗi Pull Request.

Giai Đoạn 2: Chuẩn Hóa Production & Tối Ưu Hệ Thống (P1 & Enhancements)

HẠNG MỤC	NỘI DUNG KỸ THUẬT CẦN THỰC HIỆN	MỤC TIÊU ĐẠT ĐƯỢC
Production Config	- Đổi profile mặc định Compose sang <code>prod</code> . - Tắt <code>show-sql=false</code> trong <code>application-prod.properties</code> . - Inject Redis host, Hikari pool, JWT secret qua Biến môi trường (Env vars). - Loại bỏ hoàn toàn flag <code>clean-on-validation-error</code> ở mọi môi trường.	An toàn dữ liệu, chống rò rỉ log SQL, bảo mật chia khóa hệ thống.
Auth Hardening		

HẠNG MỤC	NỘI DUNG KỸ THUẬT CẦN THỰC HIỆN	MỤC TIÊU ĐẠT ĐƯỢC
	- Hash Refresh Token (SHA-256) trước khi lưu DB. - Trả Access Token qua HttpOnly Cookie hoặc kết hợp Secure Header.	Chống tấn công Session Hijacking & XSS.
Async & Events	- Tự động hóa loyalty/totalSpent bằng Spring ApplicationEvent khi Order đạt trạng thái <code>DELIVERED</code>. - Tách Broadcast Notification sang Async Worker/Queue.	Tránh block HTTP Request, tối ưu thời gian phản hồi API.
Observability	- Tích hợp Micrometer Prometheus Registry vào Actuator. - Cấu hình Structured JSON Logging kết hợp Correlation Request ID (MDC filter).	Sẵn sàng cho việc Monitoring & Tracing sự cố trên Production.

--- Báo cáo được khởi tạo tự động dựa trên kết quả Audit Codebase dự án LaDux Backend ---